Date:25/03/2026

EX-08

Perform rootkit detection and removal using rkhunter tool.

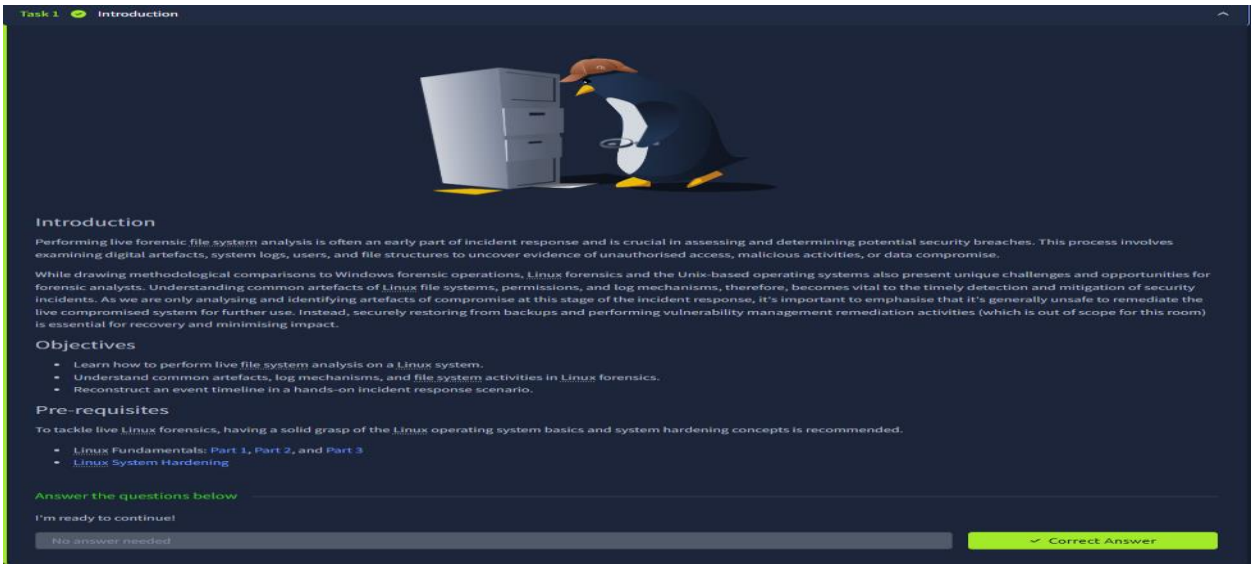
AIM:

To analyze the Linux file system and identify attacker artifacts such as hidden files, suspicious commands, and unauthorized access traces.

PROCEDURE:

- Examine user directories (e.g., `/home`) for hidden files using `ls -la`.
- Check command history files like `.bash_history` for suspicious activity.
- Search for unusual or hidden files using `find`.
- Inspect SSH-related files (e.g., `authorized_keys`) for unauthorized access.
- Use commands like `stat` to check file metadata and modification timestamps.
- Identify and collect flags or indicators of compromise.

TASK-1:



TASK-2:

Securing the Environment

While we perform live forensic analysis on this system, it is important to note that in this assumed scenario, we have already acquired all necessary backups and have isolated the system from the network to prevent further compromise or tampering.

As this is a potentially compromised host, it is a good idea to ensure we are using known good binaries and libraries to conduct our information gathering and analysis. Often, this can be done by mounting a USB or drive containing binaries from a clean Debian-based installation. This has been simulated on the attached VM by copying the */bin*, */sbin*, */lib*, and */lib64* folders from a clean installation into the */mnt/usb* mount on the affected system.

Note: The following steps should be performed after establishing an SSH connection to the *target* machine, *not on the AttackBox*.

This effort aims to mitigate the risk of inadvertently executing malicious code or compromised utilities on systems. Suppose an attacker gains privileged access to a system. In that case, they may replace or alter existing utilities with malicious binaries or libraries that could cause further harm when run by an unsuspecting investigator. By using a trusted source, it enhances the reliability and integrity of our investigation.

We can modify our `PATH` and `LD_LIBRARY_PATH` (shared libraries) environment variables to use these trusted binaries:

Modifying Environment Variables to Include Trusted Paths

```
investigator@MACHINE_IP:~$ export PATH=/mnt/usb/bin:/mnt/usb/sbin
investigator@MACHINE_IP:~$ export LD_LIBRARY_PATH=/mnt/usb/lib:/mnt/usb/lib64
```

Answer the questions below

After updating the `PATH` and `LD_LIBRARY_PATH` environment variables, run the command `check-env`. What is the flag that is returned in the output?

THM{5514ec4f1ce82f63867806d3cd95dbd8} ✓ Correct Answer

TASK-3:

which is why it's crucial to obtain forensically sound backups and copies of the affected system beforehand. Because of this, the *atime* will not be a reliable metric for us.

While it's useful to recall the three commands above, we can also leverage the `stat` command to quickly see all three timestamps at once:

Viewing Timestamps with stat

```
investigator@MACHINE_IP:~$ stat /var/www/html/assets/reverse.elf
  File: /var/www/html/assets/reverse.elf
  Size: 250         Blocks: 8          IO Block: 4096   regular file
Device: ca01h/51713d    Inode: 526643      Links: 1
Access: (0755/-rwxr-xr-x)  Uid: (   33/www-data)   Gid: (   33/www-data)
Access: 2024-02-13 02:31:29.256000000 +0000
Modify: 2024-02-13 00:26:28.000000000 +0000
Change: 2024-02-13 00:34:50.679215113 +0000
 Birth: -
```

Answer the questions below

To practice your skills with the `find` command, locate all the files that the user **bob** created in the past 1 minute. Once found, review its contents. What is the flag you receive?

THM{0b1313afd2136ca0faafb2daa2b430f3} ✓ Correct Answer

Extract the metadata from the `reverse.elf` file. What is the file's MIME type?

application/octet-stream ✓ Correct Answer

Run the `stat` command against the `/etc/hosts` file on the compromised web server. What is the full **Modify Timestamp (mtime)** value?

2020-10-26 21:10:44.000000000 +0000 ✓ Correct Answer

TASK-4:

More specifically, this line specifies:

- **richard** is the username being granted sudo privileges.
- **ALL** indicates that the privilege applies to all hosts.
- **(ALL)** specifies that the user can run the command as any user.
- `/sbin/ifconfig` is the path to the specific binary, in this case, the ifconfig utility.

With this configuration, Richard can execute `ifconfig` with elevated sudo privileges to manage network interfaces as necessary.

Answer the questions below

Investigate the user accounts on the system. What is the name of the backdoor account that the attacker created?

b4ckd00r3d — ✓ Correct Answer

What is the name of the group with the group ID of **46**?

plugdev — ✓ Correct Answer

View the `/etc/sudoers` file on the compromised system. What is the full path of the binary that Jane can run as sudo?

/usr/bin/pstree — ✓ Correct Answer

TASK-5:

If we look back to the output of the `ls -al` command, we can identify the permission misconfiguration that made this possible:

Viewing the Permissions of the authorized_keys File

```
investigator@MACHINE_IP:~$ ls -al /home/jane/.ssh/authorized_keys
-rw-rw-rw- 1 jane jane 1136 Feb 13 00:34 /home/jane/.ssh/authorized_keys
```

As identified by the third `rw` permissions, this file is world-writable, which should never be the case for sensitive files. Consequently, by exploiting this misconfiguration, the attacker gained unauthorised SSH access to the system as if they were Jane.

Answer the questions below

View Jane's `.bash_history` file. What flag do you see in the output?

THM{f38279ab9c6af1215815e5f7bbad891b} — ✓ Correct Answer

What is the hidden flag in Bob's home directory?

THM{6ed90e00e4fb7945bead8cd59e9fcd7f} — ✓ Correct Answer

Run the `stat` command on Jane's `authorized_keys` file. What is the full timestamp of the most recent modification?

2024-02-13 00:34:16.005897449 +0000 — ✓ Correct Answer

TASK-6:

```
investigator@MACHINE_IP:~$ md5sum /var/tmp/bash
7063c393************d3b340f1ad2c  /var/tmp/bash
investigator@MACHINE_IP:~$ md5sum /bin/bash
7063c393************d3b340f1ad2c  /bin/bash
```

The output above shows that the two binaries are identical, further enhancing our understanding of the attacker's actions to escalate to root.

Answer the questions below

Run the `debsums` utility on the compromised host to check only configuration files. Which file came back as altered?

/etc/sudoers — ✓ Correct Answer

What is the `md5sum` of the binary that the attacker created to escalate privileges to root?

7063c3930affe123baecd3b340f1ad2c — ✓ Correct Answer

TASK-7:

Rkhunter Example

```
investigator@MACHINE_IP:~$ sudo rkhunter -c -sk
[ Rootkit Hunter version 1.4.6 ]

Checking system commands...

  Performing 'strings' command checks
    Checking 'strings' command                          [ OK ]

  Performing 'shared libraries' checks
    Checking for preloading variables                   [ None found ]
...
```

This check will take some time to run but we have bypassed the user interaction prompts with the `-sk` argument. Afterwards, you will receive a system check summary detailing what was found.

Answer the questions below

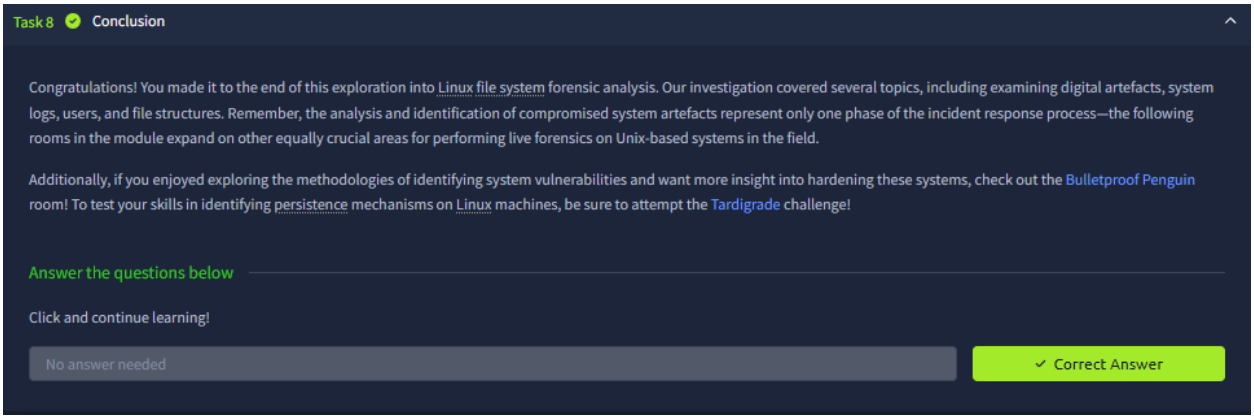
Run *chkrootkit* on the affected system. What is the full path of the `.sh` file that was detected?

/var/tmp/findme.sh — ✓ Correct Answer

Run *rkhunter* on the affected system. What is the result of the `(UID 0) accounts` check?

Warning — ✓ Correct Answer

TASK-8:



RESULT:

Attacker artifacts such as hidden flags, suspicious command history, and unauthorized SSH keys were successfully identified through file system analysis.